

The Network Inside Out

New Vantage Points for Embedded Security

J. Alex Halderman

Based on joint work:

Mining Your Ps and Qs: Widespread Weak Keys in Network Devices

Nadia Heninger, Zakir Durumeric, Eric Wustrow, and J. A. Halderman

21st USENIX Security Symposium, Aug. 2012

ZMap: Fast Internet-Wide Scanning and Its Security Applications

Zakir Durumeric, Eric Wustrow, and J. A. Halderman

22nd USENIX Security Symposium, Aug. 2013

Illuminating Security Issues Surrounding Lights-Out Server Management

Anthony Bonkoski, Russ Bielawski, and J. A. Halderman

7th USENIX Workshop on Offensive Technologies (WOOT), Aug. 2013

Green Lights Forever: Analyzing the Security of Traffic Infrastructure

Branden Ghena, William Beyer, Allen Hillaker, Jonathan Pevarnek, and J.A. H.

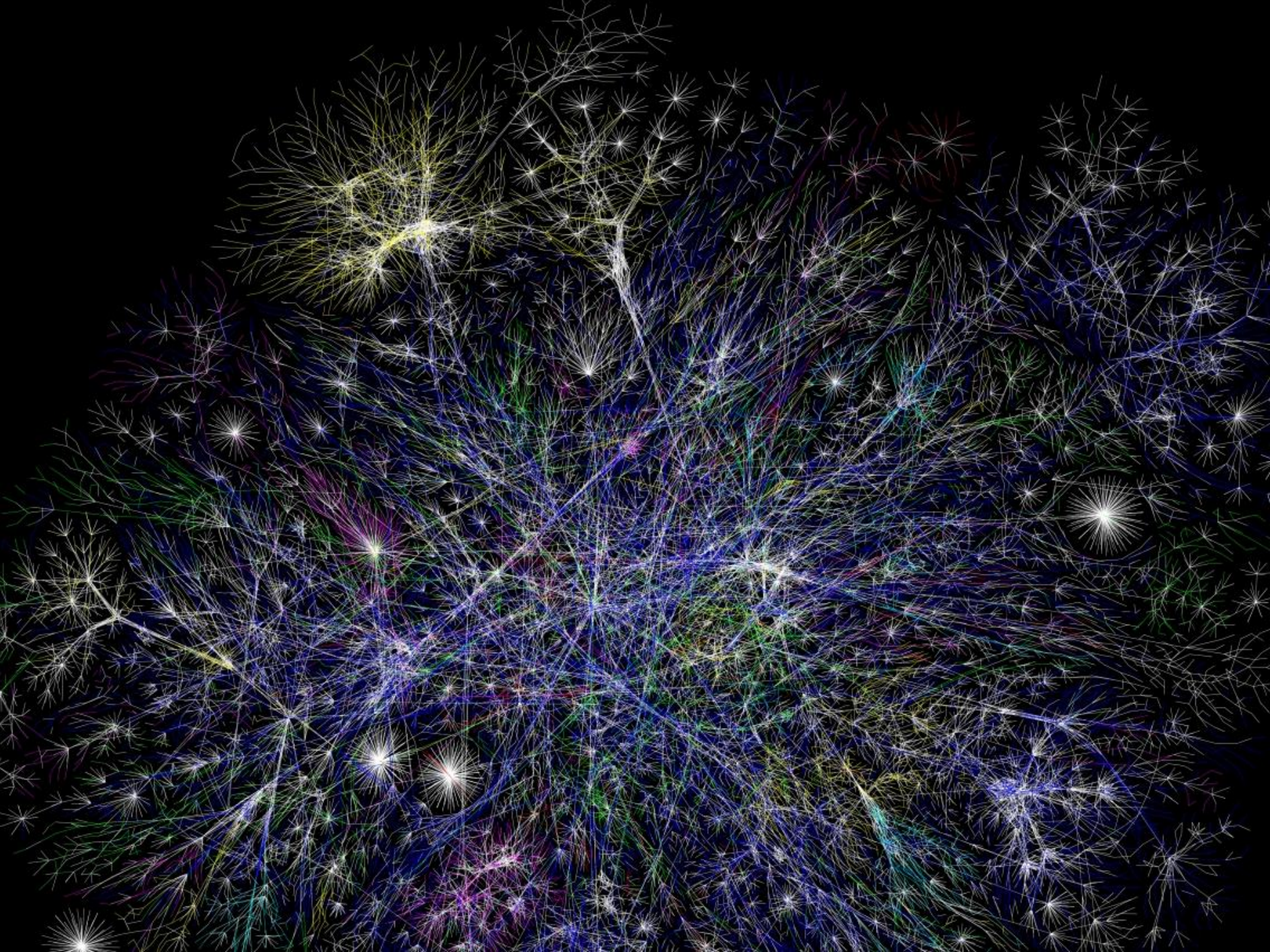
8th USENIX Workshop on Offensive Technologies (WOOT), Aug. 2014

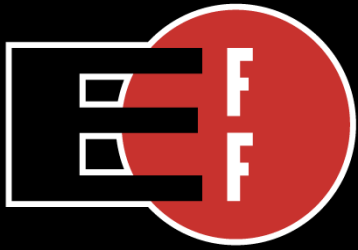
Security Analysis of a Full Body Scanner

Keaton Mowery, Eric Wustrow, Tom Wypych, Corey Singleton, Chris Comfort,

Eric Rescorla, Stephen Checkoway, J. Alex Halderman, and Hovav Shacham

23rd USENIX Security Symposium, Aug. 2014



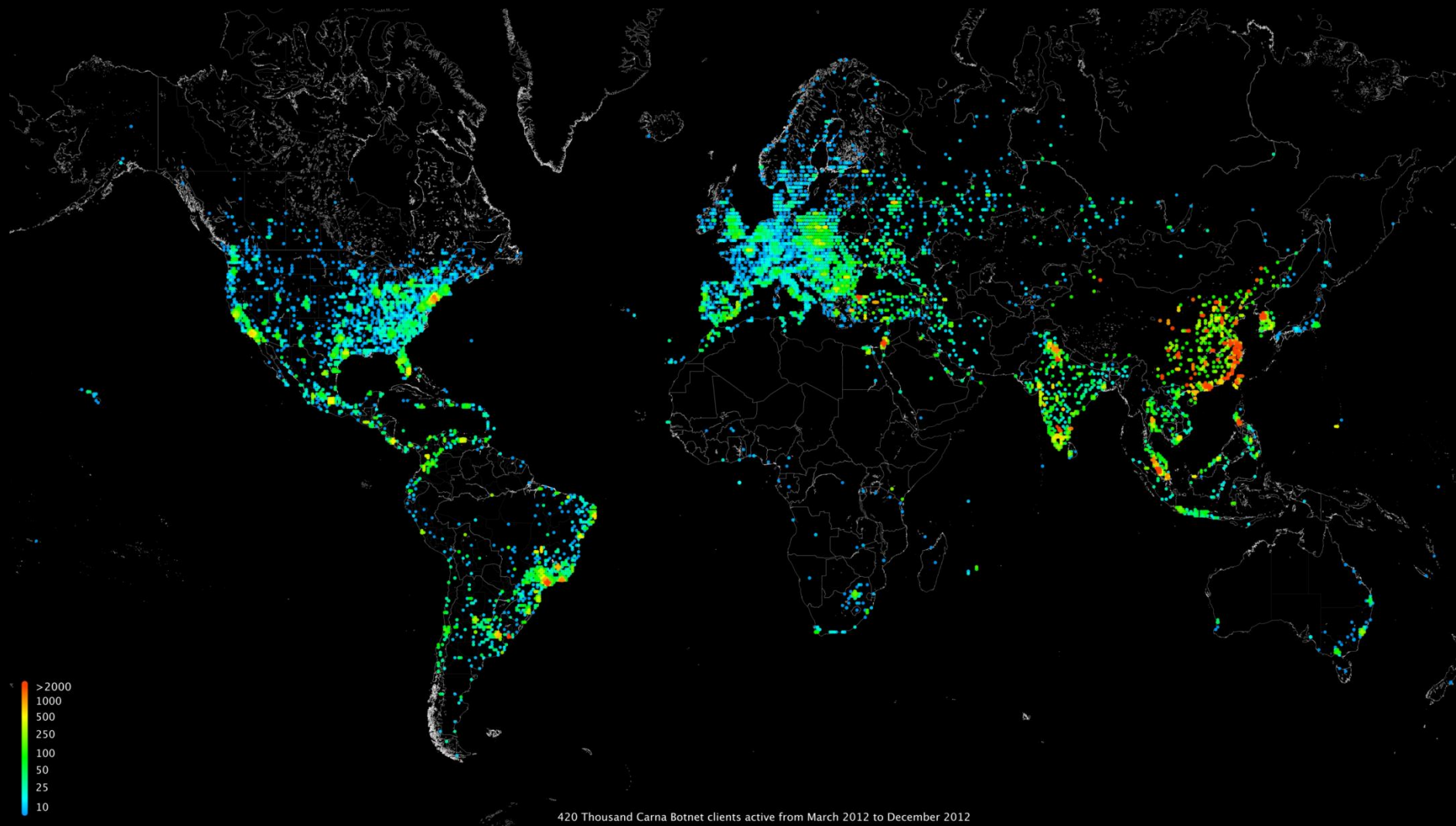


Electronic Frontier Foundation

SSL Observatory



Carna botnet Internet Census 2012



What if...?

What if Internet-wide surveys didn't require heroic effort?

What if scanning the IPv4 address space took under an hour?

What if we wrote a whole-Internet scanner from scratch?



an **open-source tool** that can port scan the entire IPv4 address space from just **one machine** in **minutes**



With ZMap, an Internet-wide TCP SYN scan on port 443 is as easy as:

```
$ sudo apt-get install zmap  
$ zmap -p 443 -o results.csv  
found 34,132,693 listening hosts  
(took 44m12s)
```

Gigabit Ethernet linespeed
(1200 x NMap)

Ethics of Active Scanning

Considerations

- Impossible to request permission from all owners
- No IP-level equivalent to robots exclusion standard
- Administrators may believe that they are under attack

Reducing Scan Impact

- Scan in random order to avoid overwhelming networks
- Signal benign nature over HTTP and w/ DNS hostnames
- Honor all requests to be excluded from future scans

Bottom Line: Be a Good Neighbor

Using ZMap Discover New Vulnerabilities

Uncovering weak cryptographic keys and poor entropy collection

We considered the cryptographic keys used by HTTPS and SSH

	HTTPS	SSH
Live Hosts	12.8 million	10.2 million
Distinct RSA Public Keys	5.6 million	3.8 million
Distinct DSA Public Keys	6241	2.8 million

There are many legitimate reason that hosts might share keys...

Shared Cryptographic Keys

Why are a large number of hosts sharing cryptographic keys?

We find that 5.6% of TLS hosts and 9.6% of SSH hosts share keys in a vulnerable manner:

- Default certificates and keys
- Apparent entropy problems

What other, more serious, problems could be present if devices aren't properly collecting entropy?

Factoring RSA Public Keys

What else could go wrong if devices aren't collecting entropy?

RSA Public Key: $n = p \cdot q$, p and q are two large random primes

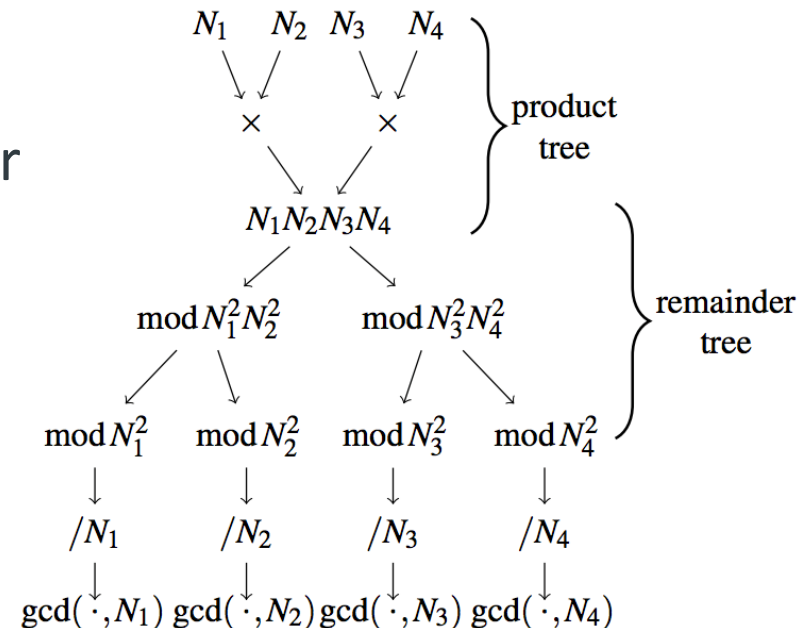
Most efficient known method of compromising an RSA key is to factor n back to p and q

While n is normally difficult to factor, for

$$N_1 = p \cdot q_1 \text{ and } N_2 = p \cdot q_2$$

we can trivially compute

$$p = \text{GCD}(N_1, N_2)$$



Broken Cryptographic Keys

Why are a large number of hosts sharing cryptographic keys?

We find 2,134 distinct primes and compute the RSA private keys for **64,081 (0.50%) of TLS hosts**

Using another approach for DSA, we are able to compute the private keys for **105,728 (1.03%) of SSH hosts**

What was causing these vulnerable keys?

CN=self-signed, CN=system generated, CN=0168122008000024
CN=self-signed, CN=system generated, CN=0162092009003221
CN=self-signed, CN=system generated, CN=0162122008001051
C=CN, ST=Guangdong, O=TP-LINK Technologies CO., LTD., OU=TP-LINK SOFT, CN=TL-R478+1145D5C30089/emailAddress
C=CN, ST=Guangdong, O=TP-LINK Technologies CO., LTD., OU=TP-LINK SOFT, CN=TL-R478+139819C30089/emailAddress
CN=self-signed, CN=system generated, CN=0162072011000074
CN=self-signed, CN=system generated, CN=0162122009008149
CN=self-signed, CN=system generated, CN=0162122009000432
CN=self-signed, CN=system generated, CN=0162052010005821
CN=self-signed, CN=system generated, CN=0162072008005267
C=US, O=2Wire, OU=Gateway Device/serialNumber=360617088769, CN=Gateway Authentication
CN=self-signed, CN=system generated, CN=0162082009008123
CN=self-signed, CN=system generated, CN=0162072008005385
CN=self-signed, CN=system generated, CN=0162082008000317
C=CN, ST=Guangdong, O=TP-LINK Technologies CO., LTD., OU=TP-LINK SOFT, CN=TL-R478+3F5878C30089/emailAddress
CN=self-signed, CN=system generated, CN=0162072008005597
CN=self-signed, CN=system generated, CN=0162072010002630
CN=self-signed, CN=system generated, CN=0162032010008958
CN=109.235.129.114
CN=self-signed, CN=system generated, CN=0162072011004982
CN=217.92.30.85
CN=self-signed, CN=system generated, CN=0162112011000190
CN=self-signed, CN=system generated, CN=0162062008001934
CN=self-signed, CN=system generated, CN=0162112011004312
CN=self-signed, CN=system generated, CN=0162072011000946
C=US, ST=Oregon, L=Wilsonville, CN=141.213.19.107, O=Xerox Corporation,
CN=XRX0000AAD53FB7.eecs.umich.edu, CN=(141.213.19.107|XRX0000AAD53FB7.ee
CN=self-signed, CN=system generated, CN=0162102011001174

Most compromised keys are generated by
headless or embedded network devices

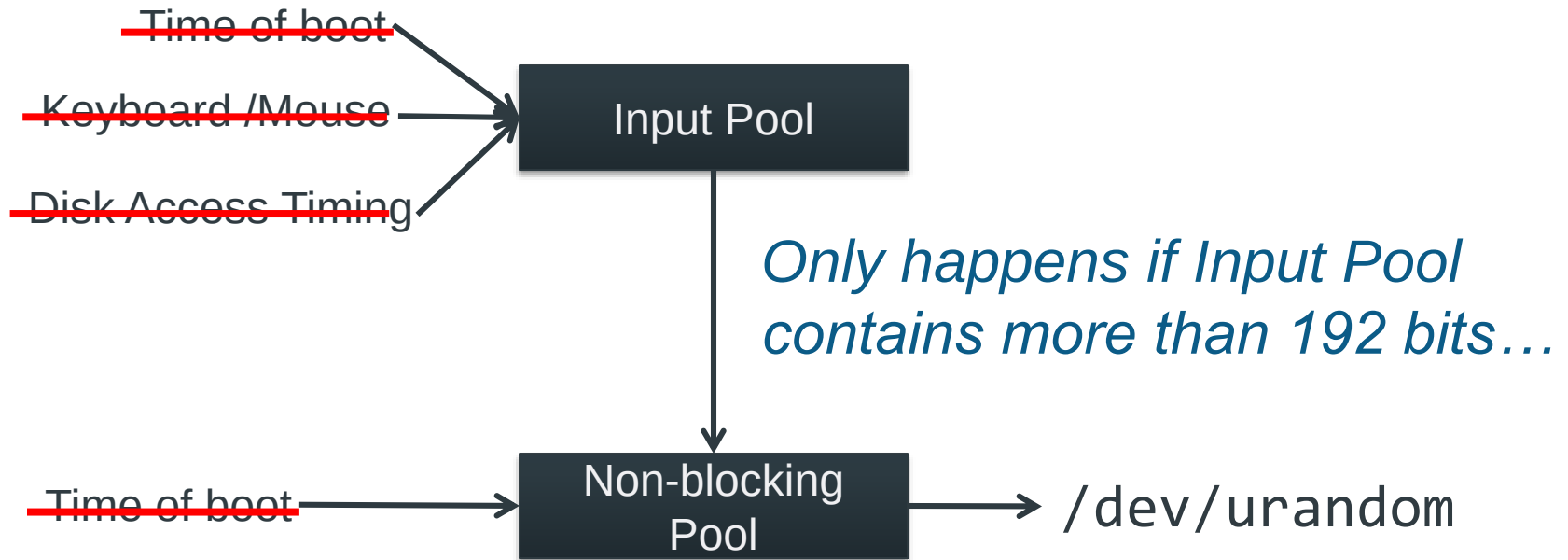
Identified devices from > 40 manufacturers



Linux /dev/urandom

Why are embedded systems generating broken keys?

Nearly everything uses /dev/urandom

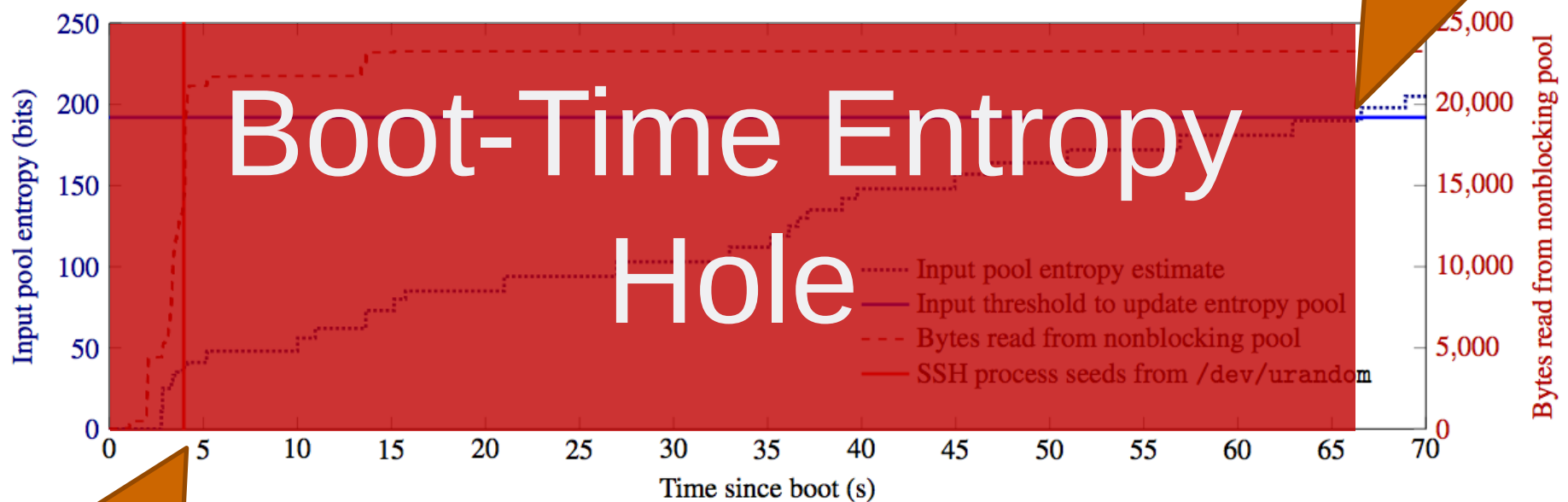


Problem 1: Embedded devices may lack all these sources

Problem 2: /dev/urandom can take a long time to “warm up”

Typical Ubuntu Server Boot

Why are embedded systems generating broken keys?



Entropy first mixed into /dev/urandom

OpenSSH seeds from /dev/urandom

/dev/urandom may be predictable for a period after boot.

Moving Forward

What do we do about fixing the Linux kernel and affected devices?

Patches have been committed to the Linux 3.x Kernel

- Use interrupts until other entropy is available
- Mix in unique information such as MAC address

Manufacturers have been notified. DHS, ICS-CERT, NSA, JPCERT, and other agencies are working with affected companies and helping manufacturers correct vulnerabilities.

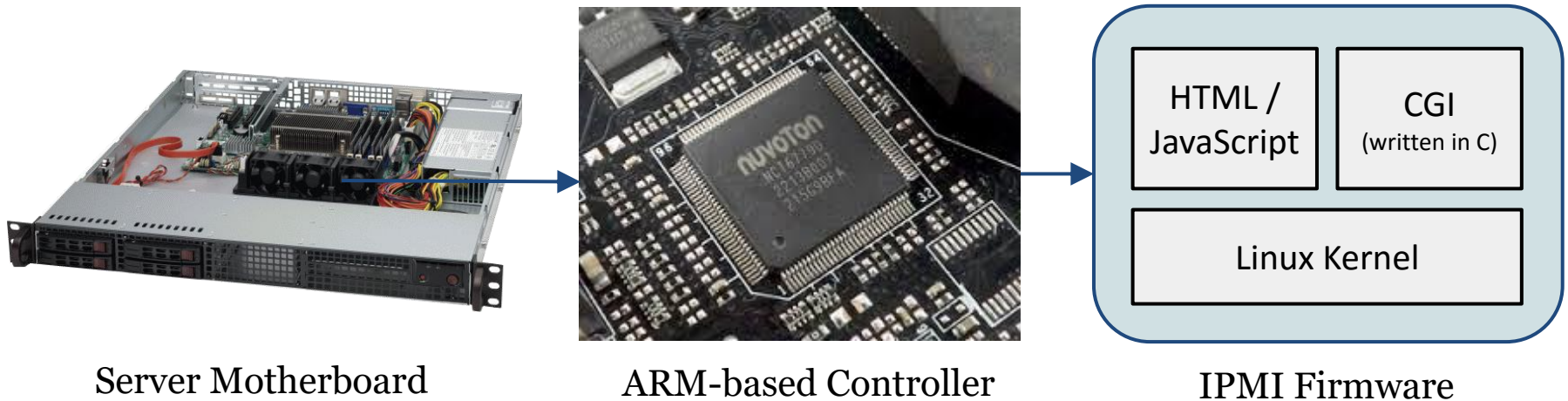
Online Key Check Service available at <https://factorable.net>

ZMap: Applications

We did [> 500 Internet-wide scans](#) over 3 years (> 2 trillion probes).
Please ignore probes from 141.212.121.0/24. It's just our one machine.

What can researchers do with ZMap?

Expose and Fix Vulnerable Devices



ZMap: Applications

SuperMicro IPMI Vulnerabilities (2013)

Server backend:

... CGI programs.

... written in C.

... running as root.

```
// login.cgi
int main(void)
{
    char name[128], pwd[24];
    char *temp ;
    // ... initialize ...
    temp = cgiGetVariable("name");
    strcpy(name, temp);
    temp = cgiGetVariable("pwd");
    strcpy(pwd, temp);
    // ... authenticate user ...
}
```

ZMap: Applications



Please Login

Username

Password

login

ZMap: Applications

1. Scanned all public IPs using ZMap for TCP/443
2. Downloaded all X.509 certs from HTTPS servers.
3. Used identifying characteristics of default certificates:

SuperMicro IPMI Subject contains “linda.wu@supermicro.com” or “doris@aten.com.tw”

Dell iDRAC Subject contains “iDRAC”

HP iLO Subjects contains “CN=iLO” and issuer contains “iLO3 Default Issuer”

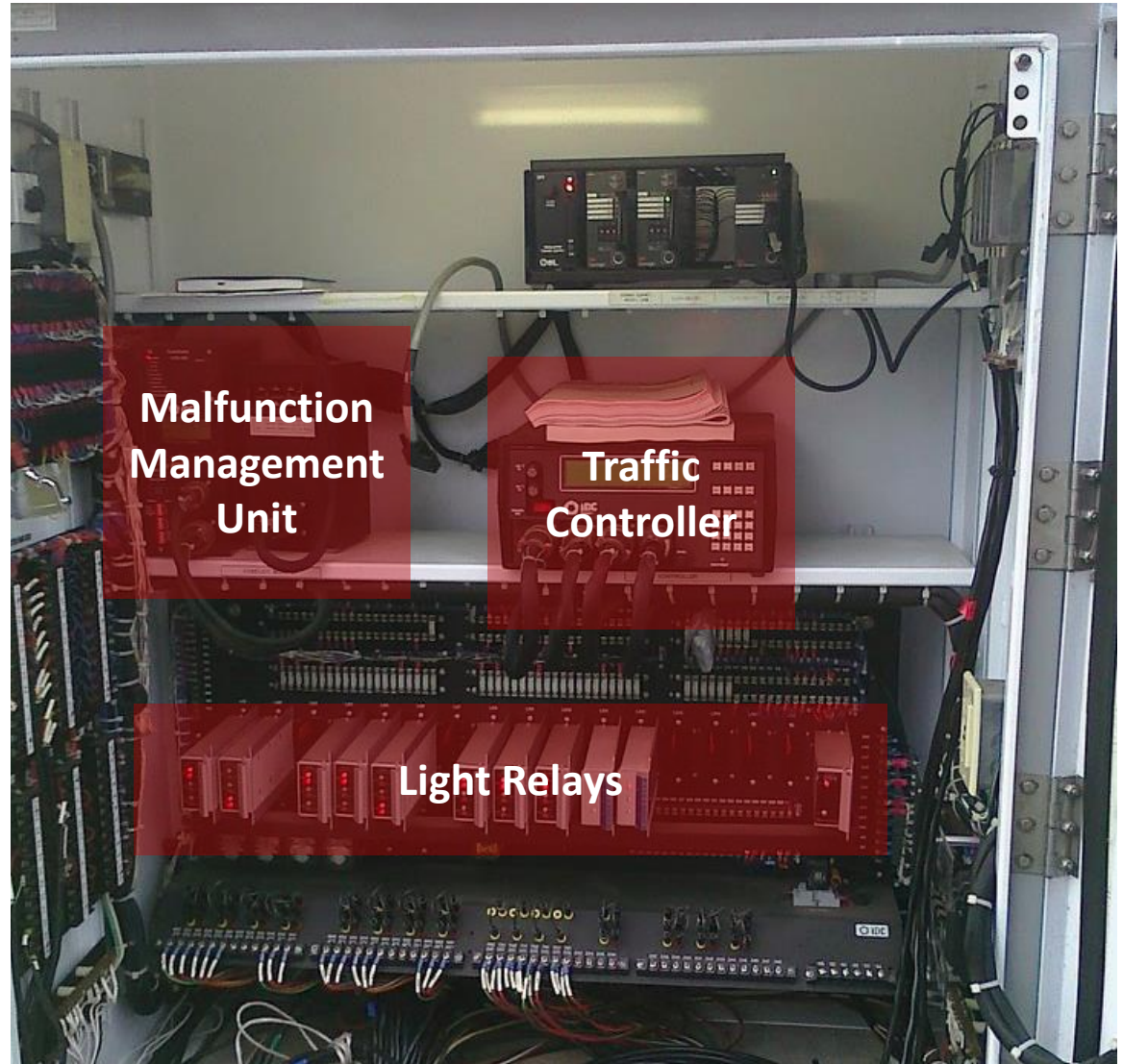
Platform	Devices on Public IPs
Supermicro IPMI	41,545
Dell iDARC	40,413
HP iLO	23,376
Total	105,334

Could root all
these in
parallel in
seconds!

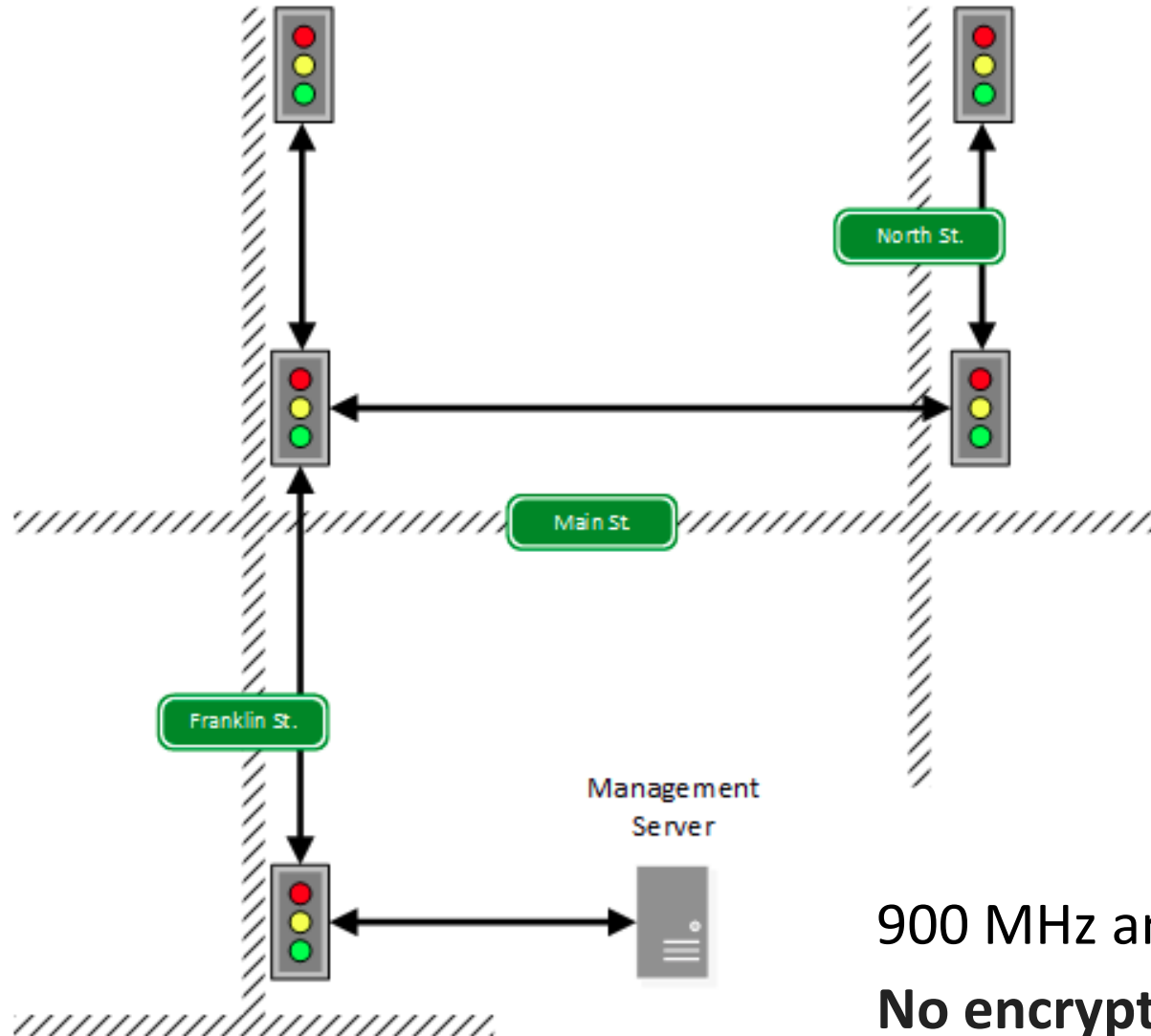
What else might show up in scans?



Inside the Traffic Cabinet



Deployment's Wireless Network



900 MHz and 5.8 GHz
No encryption!

Inside the Traffic Controller

Runs VxWorks. Default build leaves a debug port open.
Arbitrary access to read and write memory.
Patch available but not applied to unit we tested.

NTCIP 1202 Protocol

- National Transportation Communications for ITS Protocol (Standard defining communications for traffic controllers)
- SNMP used to manage devices
- Does not provide protection from unauthorized access



We created tools to sniff and inject commands.



1. Connected to network
2. Ran controller shell
3. Changed light on command!

MMU...?

Prevents four-way green, but not denial-of-service, congestion attacks.



Heartbleed Vulnerability

In April 2014, OpenSSL disclosed a catastrophic bug in their implementation of the TLS Heartbeat Extension

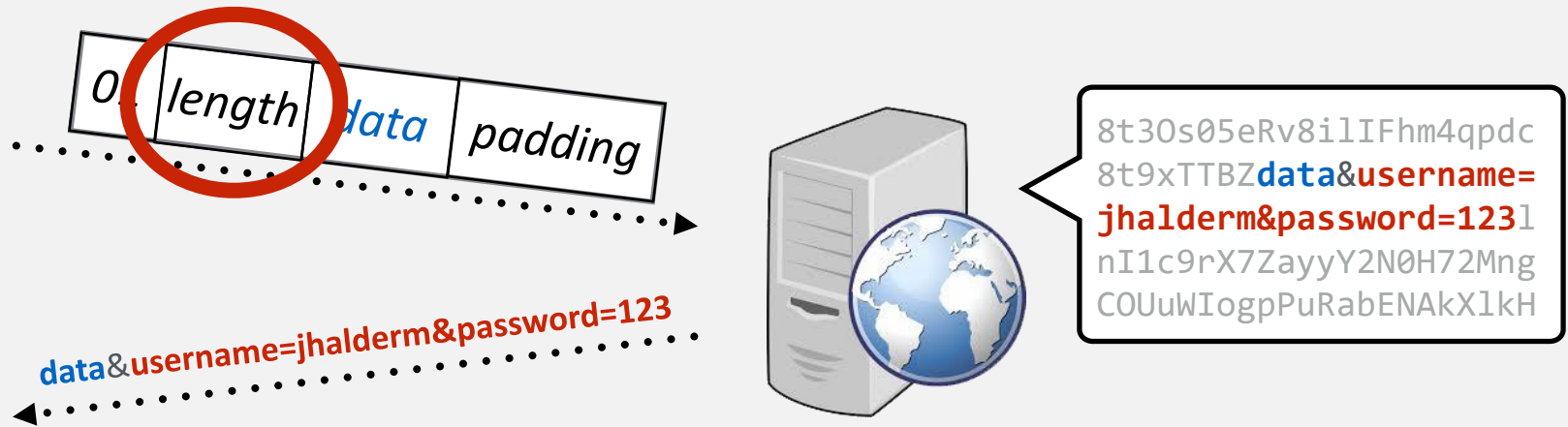
Vulnerability allowed attackers to dump private cryptographic keys, logins, and other private user data

Potentially effected any service that used OpenSSL for TLS—including web, mail, messaging and database servers

An estimated **24-55%** of HTTPS websites were initially vulnerable

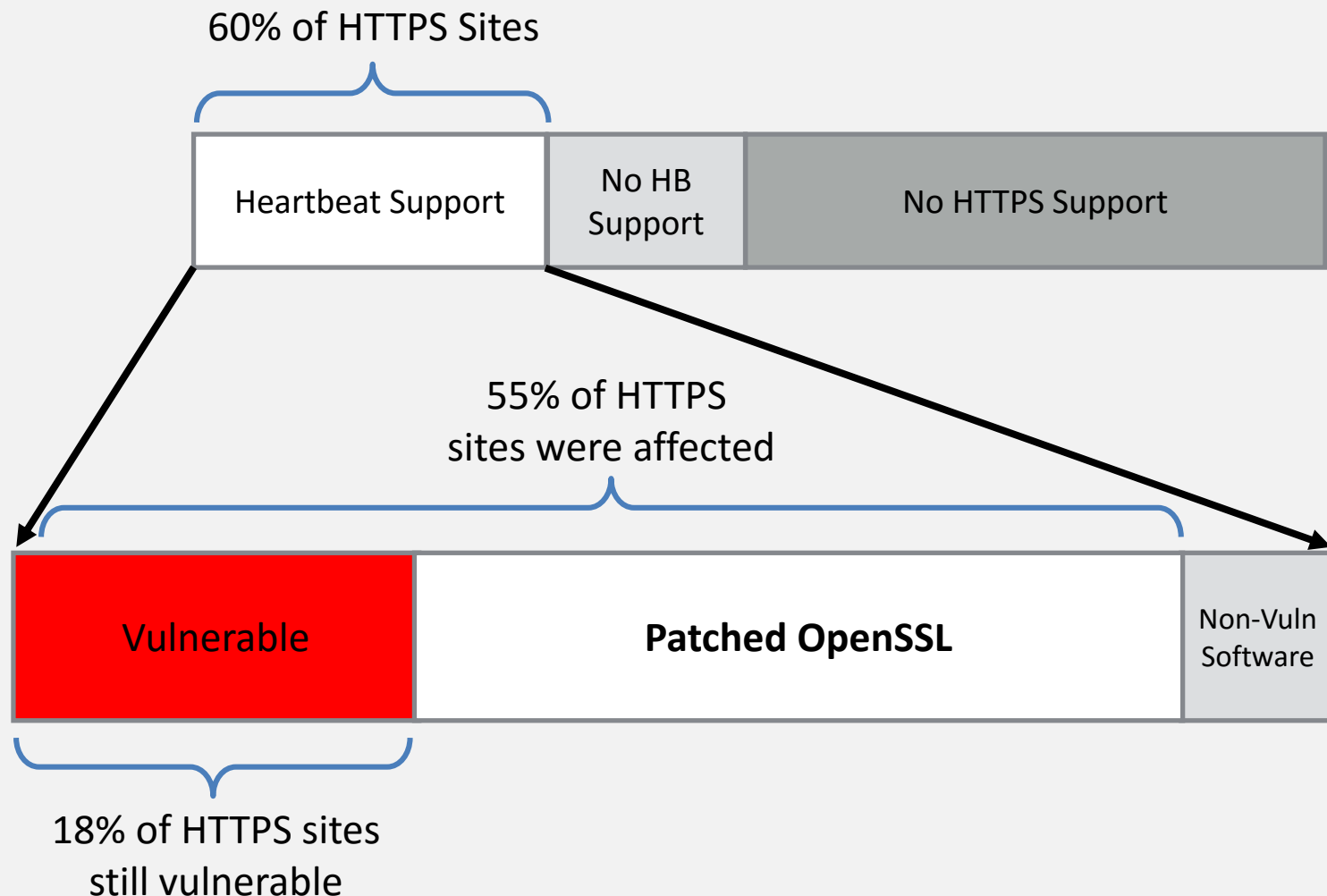


Heartbleed Vulnerability

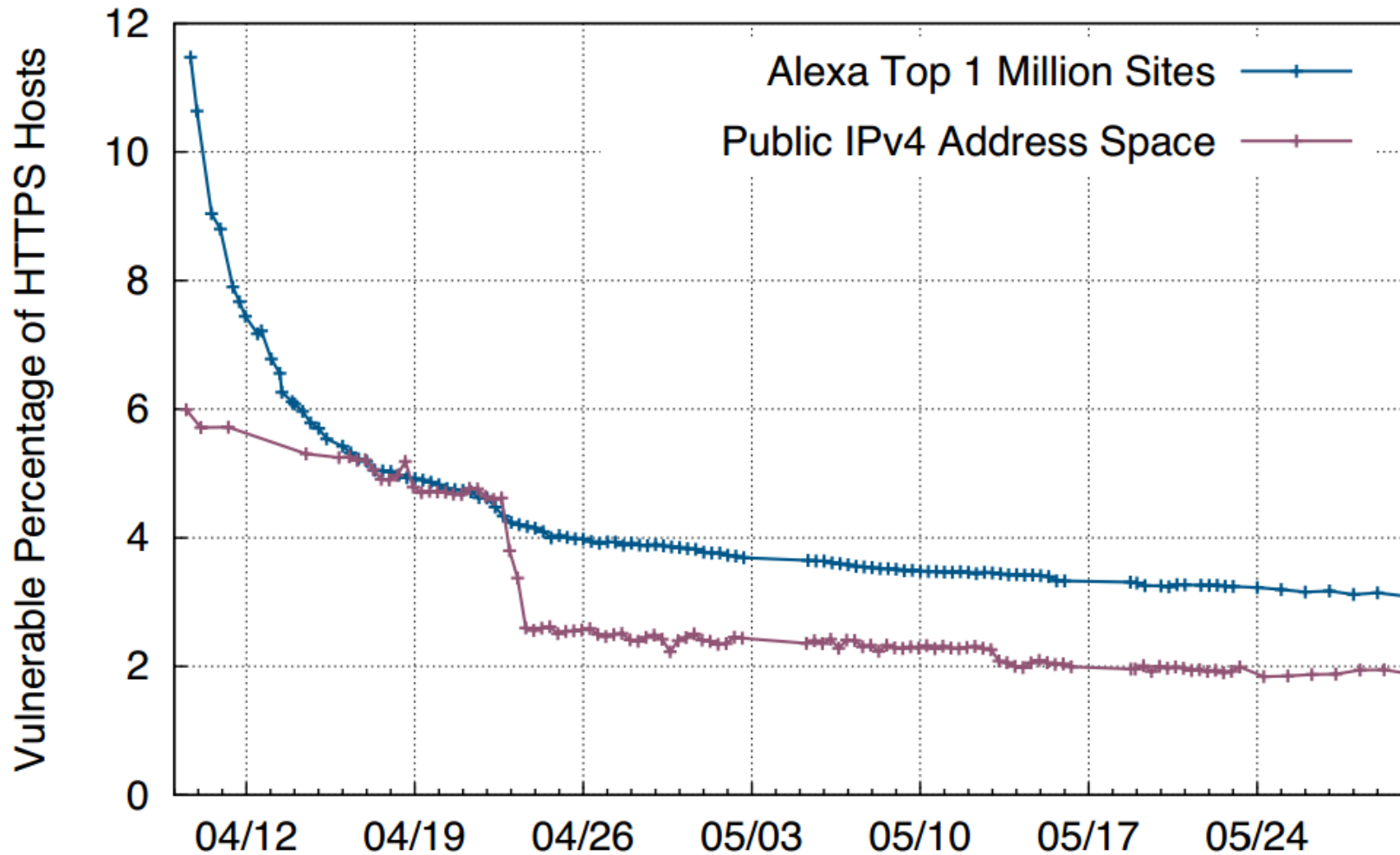


Heartbleed Vulnerability: OpenSSL trusts user provided length field and echoes back memory contents following request data

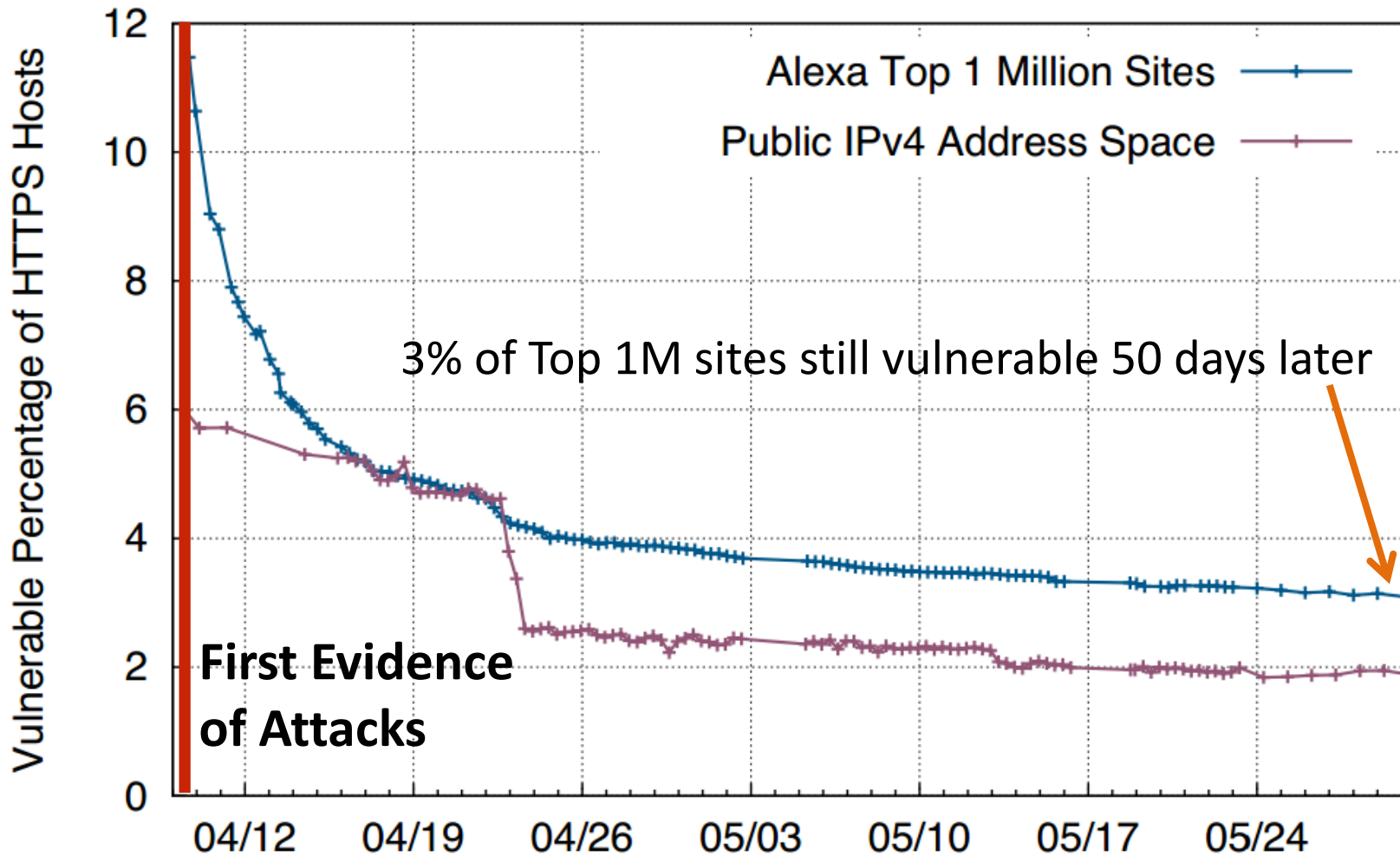
Initial Results – Disclosure +2 Days



Patching Over Time



Patching Over Time



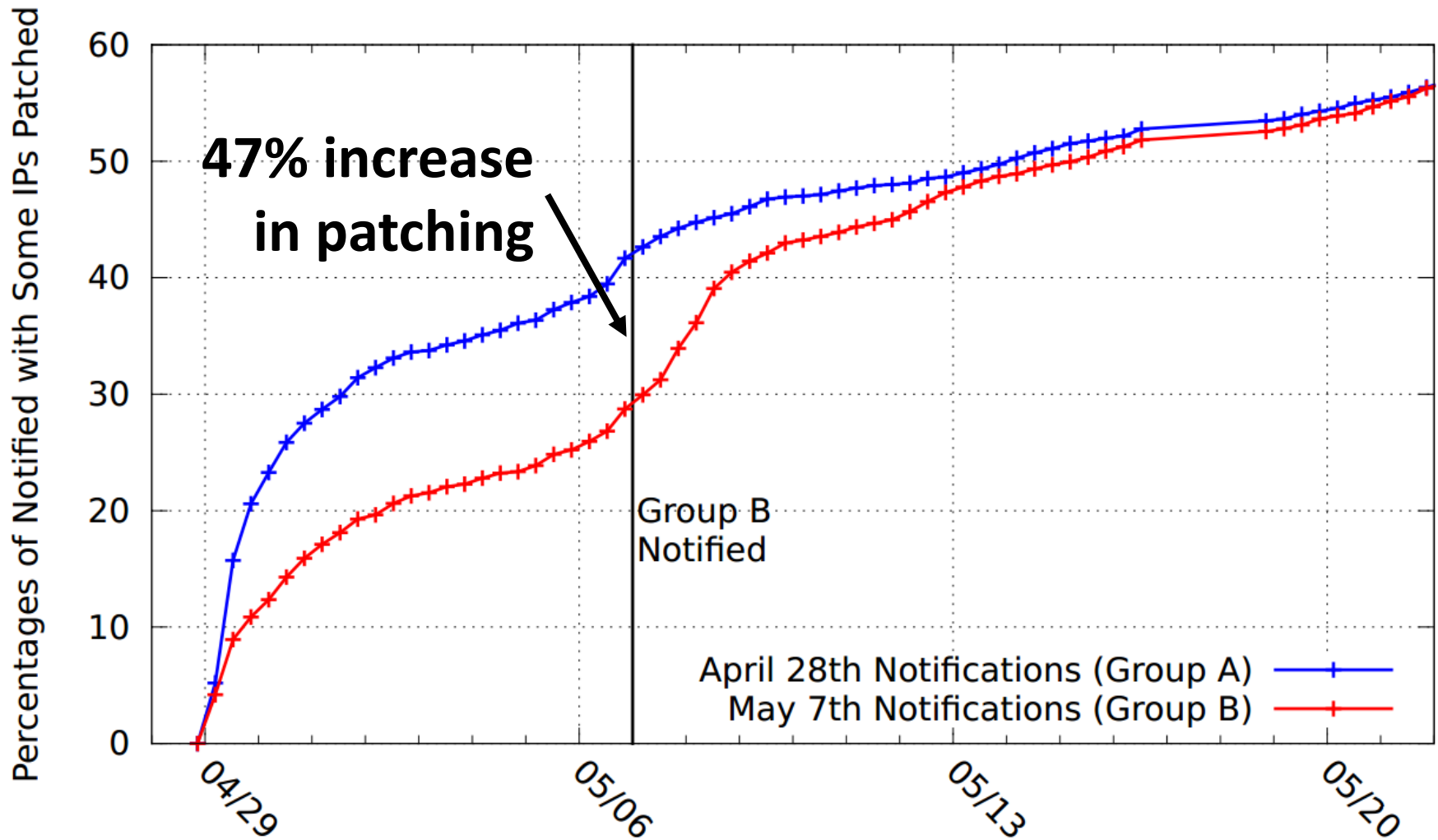
Vulnerability Notifications



April 24 scan discovered 588,000 hosts still vulnerable.

What to do?

Vulnerability Notifications



Coming at ACM CCS 2015:

Logjam and Diffie-Hellman Weaknesses

1. TLS downgrade attack to 512-bit “export grade” DH.

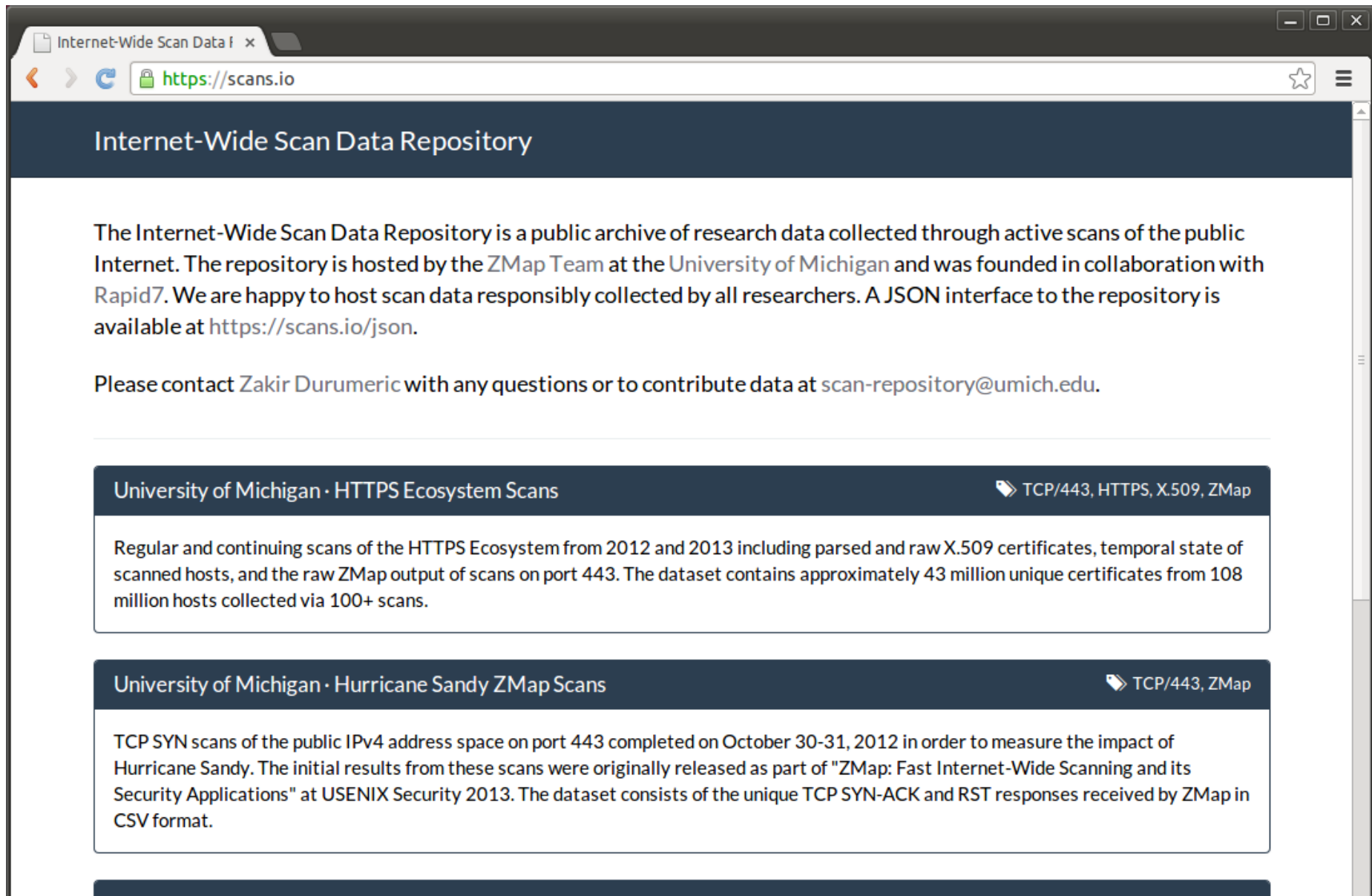
We can MITM 8% of Top 1 Million HTTPS sites.

2. State-level attackers are likely cracking 1024-bit DH today.

They can sniff 66% of VPNs, 25% of SSH, 20% of HTTPS.

Details and preprint at <https://weakdh.org>

Getting Involved – Scans.io Data Repository



The screenshot shows a web browser window with the address bar displaying <https://scans.io>. The page title is "Internet-Wide Scan Data Repository". The main content area contains a paragraph about the repository, a contact email, and two data scan listings. The first listing is for "University of Michigan · HTTPS Ecosystem Scans" and the second is for "University of Michigan · Hurricane Sandy ZMap Scans".

Internet-Wide Scan Data Repository

The Internet-Wide Scan Data Repository is a public archive of research data collected through active scans of the public Internet. The repository is hosted by the ZMap Team at the University of Michigan and was founded in collaboration with Rapid7. We are happy to host scan data responsibly collected by all researchers. A JSON interface to the repository is available at <https://scans.io/json>.

Please contact Zakir Durumeric with any questions or to contribute data at scan-repository@umich.edu.

University of Michigan · HTTPS Ecosystem Scans  TCP/443, HTTPS, X.509, ZMap

Regular and continuing scans of the HTTPS Ecosystem from 2012 and 2013 including parsed and raw X.509 certificates, temporal state of scanned hosts, and the raw ZMap output of scans on port 443. The dataset contains approximately 43 million unique certificates from 108 million hosts collected via 100+ scans.

University of Michigan · Hurricane Sandy ZMap Scans  TCP/443, ZMap

TCP SYN scans of the public IPv4 address space on port 443 completed on October 30-31, 2012 in order to measure the impact of Hurricane Sandy. The initial results from these scans were originally released as part of "ZMap: Fast Internet-Wide Scanning and its Security Applications" at USENIX Security 2013. The dataset consists of the unique TCP SYN-ACK and RST responses received by ZMap in CSV format.

Encrypt All the Things!



HTTPS is imperfect, but *far better* than no encryption.

Yet adoption remains poor...

- Less than half of Top Million sites support HTTPS

- Less than 5% of all HTTPS servers

Barriers to adoption:

- Administrative burden

- High rate of human error

- Cost of certificates

- Forgotten embedded devices

Encrypt All the Things!



LAUNCHING IN 2015:

Let's Encrypt

A CERTIFICATE AUTHORITY TO
ENCRYPT THE ENTIRE WEB

GEN. SERIAL

S06-20-

RAPISCAN SYSTEM

EL SEGUNDO

CA 9025



CAUTION
X-RAYS

EQUIPMENT PRODUCES
X-RAYS WHEN ENERGIZED

Full Body Scanners



Rapiscan
systems





Mouse over image to zoom

[Sell one like this](#)

Rapiscan Secure 1000 DP (Dual Pose) Backscatter Body Scanner (Never installed)

Item condition: **New other (see details)**

History: 1 offer

Price: US \$49,500.00

[Buy It Now](#)

[Add to cart](#)

Best Offer:

[Make Offer](#)

[Add to Watch list](#)

| [Add to Watch list](#)

Seller information

ivw-agne(353)

99.6% Positive feedback

[Save this seller](#)

[See other items](#)

Visit store: **IVW AGNE**

Registered as a Business Seller

Shipping: **\$2,000.00** Standard Shipping | [See details](#)

International items may be subject to customs processing and additional charges.

Item location: **Castrop-Rauxel, Germany**

Ships to: **Worldwide**

Delivery: **Estimated between Mon. Oct. 22 and Fri. Oct. 26**

This item has an extended handling time and a delivery estimate **greater than 10 business days**. Please allow additional time if international delivery is subject to customs processing.

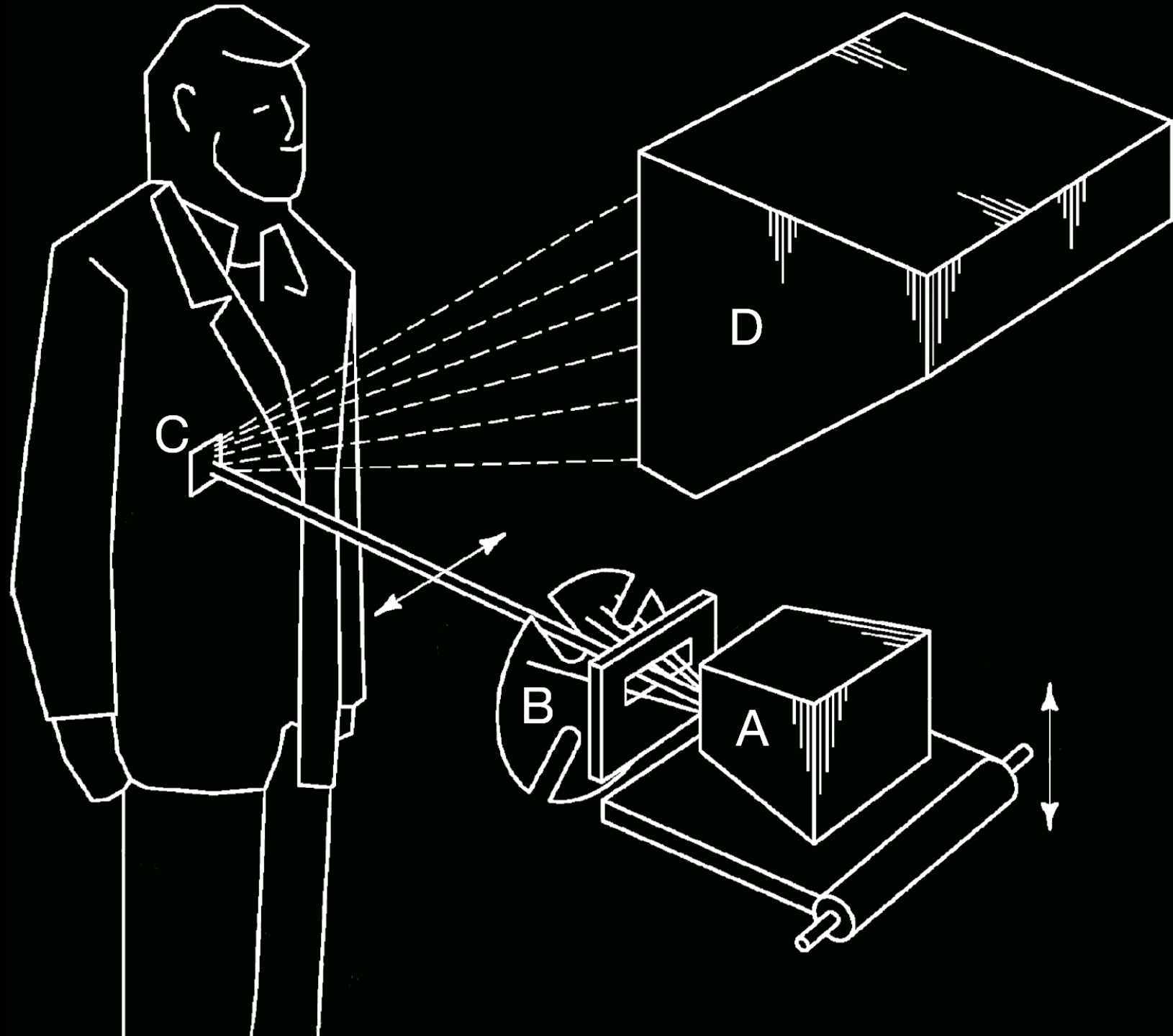
Payments: **PayPal** | [See details](#)

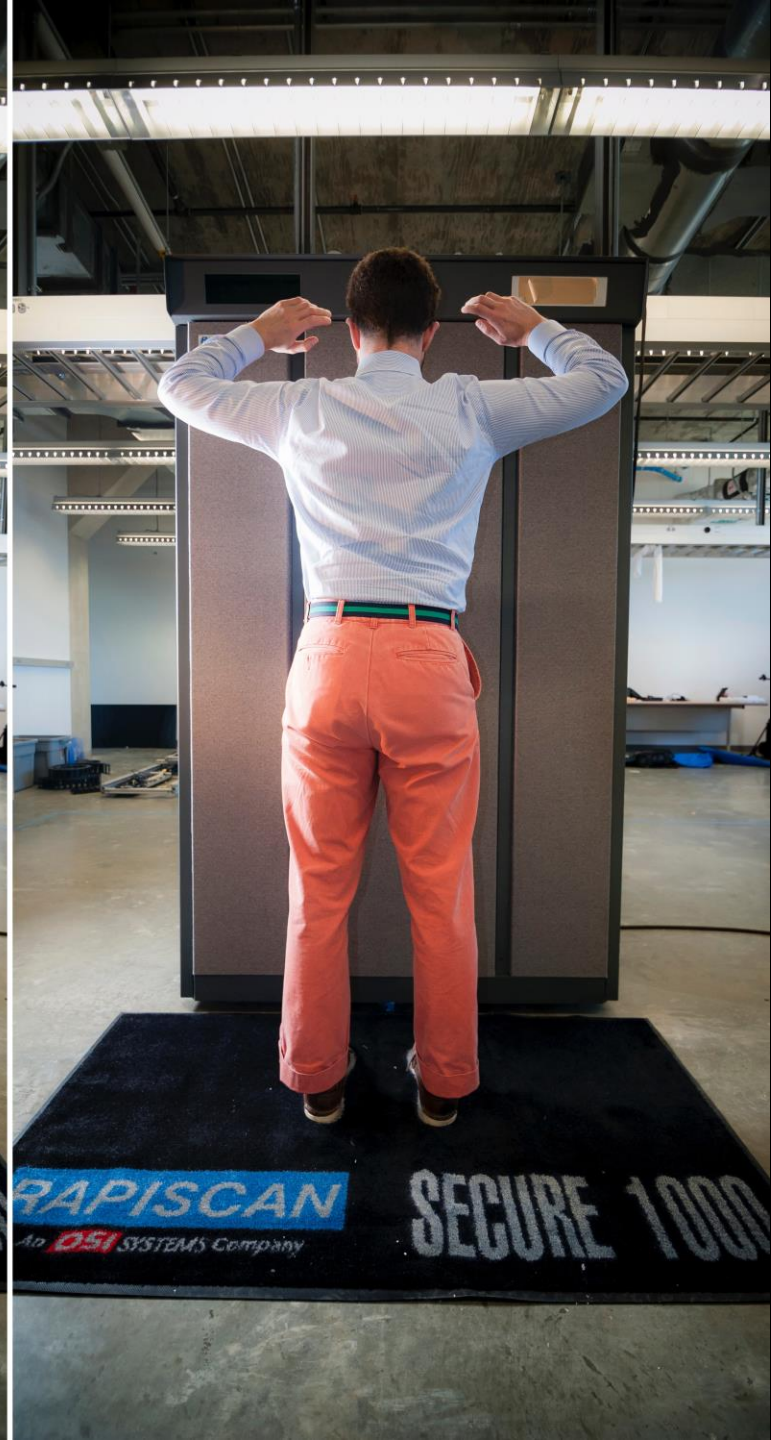
Returns: No returns or exchanges, but item is covered by **eBay Buyer Protection**.

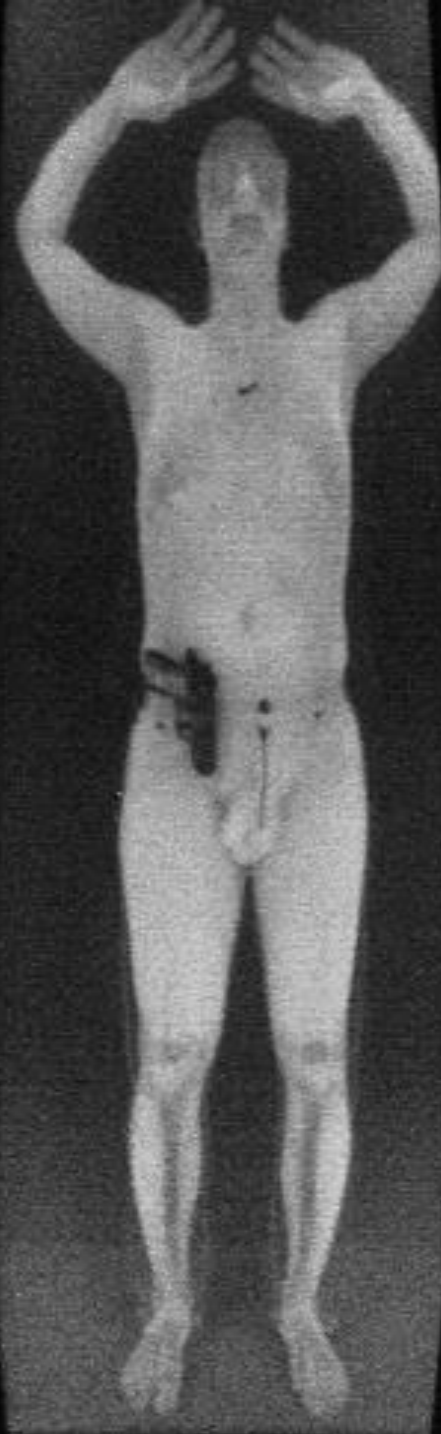
AdChoice

ebay MONEY BACK GUARANTEE
Covers your purchase price and original shipping.
[Learn more](#)









Operator Software



SECURE 1000™ personnel screening system
Rapiscan Security Products, Hawthorne, CA
FOR USE BY QUALIFIED OPERATORS ONLY

scan
zoom
clear
redraw
→ save
recall
comments
options

Press ENTER to
save images to
the haddisk.

Press the ↑↓
keys to select
another action.

08-14-14 11:16

Control Malware

Operator's View

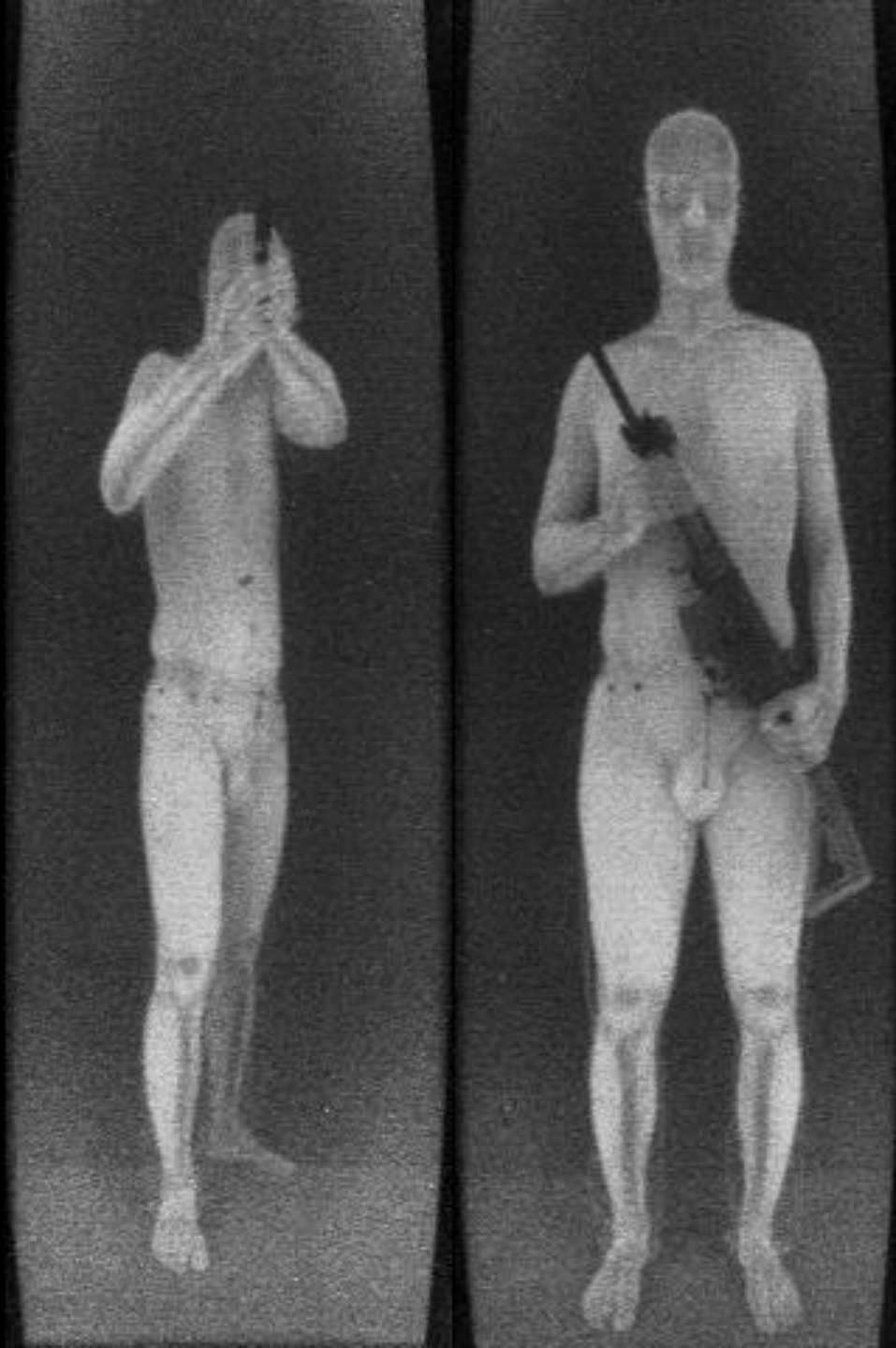


“Secret knock”



X-ray

Efficacy?



Efficacy?

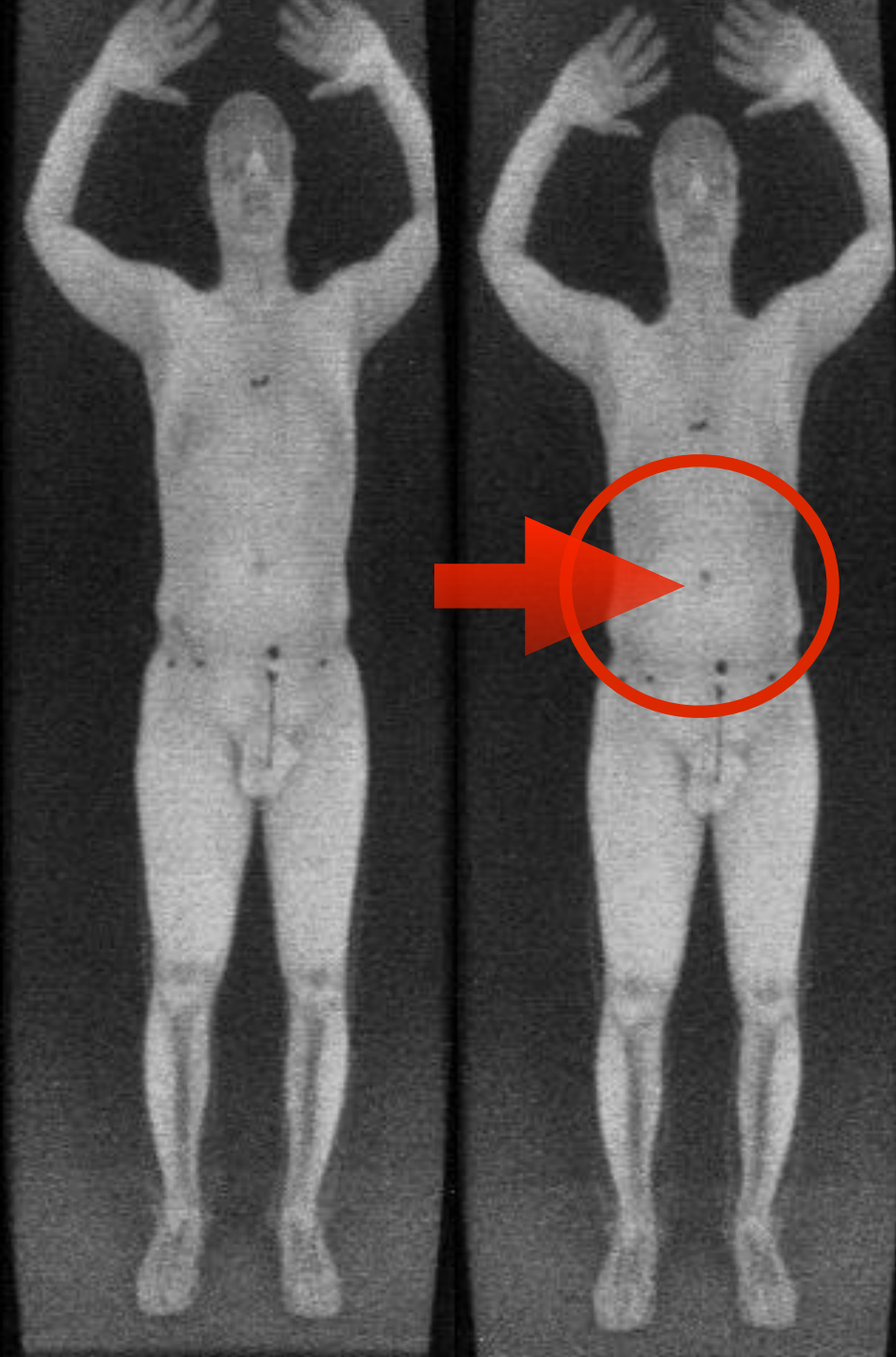
Subject carrying
a pistol



Efficacy?

Subject carrying
plastic explosives
vs.

No contraband



The effectiveness of the device is constrained by facts of X-ray physics and ability to protect embedded software against compromise.

TSA purchased 251 Secure 1000 scanners, at cost of \$40,077,571.

Either TSA's process didn't find the flaws we did...
or TSA uncovered flaws but deployed them anyway!

Thank You!

J. Alex Halderman

<https://jhalderm.com>

ZMap Internet-wide scanner

<https://zmap.io>

Scan data repository

<https://scans.io>

Logjam attack

<https://weakdh.org>

Let's Encrypt CA

<https://letsencrypt.org>